SIMATS ENGINEERING

ASSESSMENT TOOL 1- Enumeration Analysis

COURSE CODE: ITA14 **COURSE NAME: Ethical Hacking**

COURSE OUTCOME COVERED

CO3: *Analyse network services using port scanning, ping sweeps, and enumeration techniques across different operating systems to identify vulnerabilities.* *(BL3)*

Assessment Tool Weightage: 40%

QUESTIONS: 5 **Total Marks:100**

1. A cyber security consulting company has been contracted to perform an initial security assessment of the publicly accessible server **scanme.nmap.org**. Before conducting any vulnerability assessment, the client requires a detailed enumeration report. Using **Nmap**, perform host discovery, TCP port scanning, service version detection, operating system fingerprinting, and default script scanning on **scanme.nmap.org**. Analyze all identified ports and services, determine their business purpose, and evaluate whether they are necessary for public access. Discuss how a threat actor could utilize the information gathered during enumeration to launch further attacks such as service exploitation, brute-force attacks, or vulnerability discovery. Prepare a technical report summarizing your findings, attack surface analysis, risk assessment, and recommendations for securing the server.
2. The security team has deployed a deliberately vulnerable Linux server, **192.168.56.101 (Metasploitable 2)**, in an isolated laboratory environment to train penetration testers. As part of the pre-engagement reconnaissance phase, use **Nmap** to perform comprehensive enumeration of **192.168.56.101**. Identify all open ports, running services, service versions, and operating system information. Analyze the purpose of each service and determine which services could provide potential entry points for an attacker. Categorize the discovered services into High, Medium, and Low risk levels based on their exposure and functionality. Explain how the enumeration results could guide a penetration tester in selecting potential attack vectors and exploitation strategies.
3. A financial organization wants to assess the security posture of a Windows workstation located at **192.168.56.102** before connecting it to the production network. Using **Nmap**, enumerate **192.168.56.102** to identify active ports, network services, file-sharing protocols, remote management services, and operating system details. Analyze whether the discovered services comply with the principle of least privilege and identify any services that may unnecessarily increase the attack surface. Discuss how an attacker could leverage the identified services for reconnaissance, lateral movement, or unauthorized access. Based on your findings, propose a set of security hardening measures to improve the system's resilience against cyberattacks.

4. An organization hosts a web application on **192.168.56.103 (OWASP Juice Shop Server)** and plans to conduct a full penetration test. Before the testing phase begins, the security team must understand the server's network exposure. Using **Nmap**, perform a detailed enumeration of **192.168.56.103**, including host discovery, port scanning, service version detection, operating system fingerprinting, and web service identification. Analyze the discovered services and determine how they support the hosted web application. Evaluate the risks associated with exposed web services, administrative interfaces, and supporting services. Explain how the information gathered during enumeration could be used to identify potential vulnerabilities in the web application environment and recommend measures to minimize exposure
5. The network gateway device at **192.168.56.1** serves as the primary access point between the internal laboratory network and external networks. The network administrator suspects that unnecessary management services may be exposed. Using **Nmap**, conduct a comprehensive enumeration of **192.168.56.1**, including port scanning, service detection, operating system fingerprinting, and script-based enumeration. Identify all exposed management interfaces, network services, and accessible resources. Analyze the security implications of exposing services such as SSH, Telnet, SNMP, HTTP, or HTTPS management interfaces. Discuss how attackers could exploit misconfigured management services to gain unauthorized access to the network infrastructure. Based on your analysis, recommend security controls and best practices to secure the gateway device and reduce the risk of compromise.

Code of Conduct:

I D.Hasini/192425147 *(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

Signature of the student:



ANSWERS

1. Enumeration of scanme.nmap.org - findings, attack-surface analysis, risk assessment and recommendations. (20 Marks)

Conceptual Understanding (20%)

scanme.nmap.org is the host the Nmap project provides for people to practise scanning legally and lightly, so it is used here as the training target. Enumeration is the phase of a security assessment where open ports, running services, their versions and the operating system are identified and documented, before any exploitation is attempted. It turns a bare IP address into a list of concrete entry points, which is the input every later vulnerability assessment needs.

Model Design (25%)

Assessment plan (model): (1) host discovery to confirm the target is up, (2) a full TCP port scan to find every open port, (3) service/version detection on those ports, (4) OS fingerprinting, (5) default NSE scripts for extra detail, then analysis of purpose, necessity and risk for each finding.

Tool Usage (20%)

Commands used:

```
nmap -sn scanme.nmap.org                # 1. host discovery (ping scan)
nmap -p- scanme.nmap.org                # 2. full TCP port scan (all 65535 ports)
nmap -sV scanme.nmap.org                # 3. service/version detection
nmap -O scanme.nmap.org                 # 4. OS fingerprinting
nmap -sC scanme.nmap.org                # 5. default script scan
nmap -A scanme.nmap.org                 # combined: -O -sV -sC + traceroute
```

Typical results for this host (confirm against your own scan output and attach its screenshot):

Port / Service	Likely purpose	Needed publicly?
22/tcp ssh (OpenSSH)	Remote administration	Only if remote management is required; should be restricted
80/tcp http (Apache)	Demonstration web page	Yes, this is the service the host is meant to showcase
9929/tcp nping-echo	Nmap’s own echo/test service	No - a leftover test service, not a production need
31337/tcp (tcpwrapped/Elite)	Unidentified / legacy test port	No - unusual high port, should be investigated and closed if unused

Analysis of Results (20%)

Business purpose and necessity: the web service is the intended public function of this host. SSH is a legitimate administrative service but should never be open to the entire internet without restriction (IP allow-list, VPN or key-only login). The two unusual high ports have no public business purpose and widen the attack surface for no benefit; they should be closed or justified.

How a threat actor could use the enumeration output:

- **Service exploitation:** the exact Apache/OpenSSH version is matched against public CVE databases to pick a known exploit for that version.
- **Brute-force attacks:** SSH is a direct target for password guessing or credential-stuffing once it is known to be open.
- **Vulnerability discovery:** default and unexplained ports (9929, 31337) invite further probing, since unusual services are often mis-hardened.

- **Attack chaining:** OS fingerprinting narrows down which exploits and privilege-escalation techniques will work once any foothold is gained.

Risk assessment: SSH exposure is rated medium-high (direct admin access if weak credentials exist); the unidentified high ports are rated medium (unknown service, unclear purpose); the web port is low risk by itself but should be kept patched since it is the intended public face.

Documentation (15%)

Recommendations: close or firewall the unused high ports (9929, 31337) after confirming nothing depends on them; restrict SSH to management IP ranges or a VPN, use key-based login and disable password authentication; keep Apache and OpenSSH patched to current versions; hide version banners; enable logging/alerting for connection attempts; and re-run the same enumeration after remediation to confirm the attack surface was reduced.

2. Metasploitable 2 (192.168.56.101, isolated lab) - full enumeration, risk categorization and attack-vector guidance. (20 Marks)

Metasploitable 2 is a deliberately vulnerable Linux VM published for training in an isolated lab, as stated in the scenario; it is never exposed to a real network.

Conceptual Understanding (20%)

Metasploitable 2 intentionally runs many outdated services so that trainees can practise enumeration and exploitation safely. The goal here is reconnaissance only: build a complete inventory before any exploitation step, and learn to prioritize targets by risk.

Model Design (25%)

Plan: full port scan, version detection, OS detection, then group every service into High/Medium/Low risk by its exposure and what access it could give if compromised.

Tool Usage (20%)

Commands used:

```
nmap -p- 192.168.56.101                    # all open TCP ports
nmap -sV -O 192.168.56.101                 # service versions + OS fingerprint
nmap -sC -sV -p1-65535 192.168.56.101      # default scripts on every open port
```

Typical open ports on Metasploitable 2 (well documented for this training image; verify against your own lab scan):

Port	Service	Risk level	Why
21/tcp	FTP (vsftpd, known backdoored build)	High	Historically carries a known backdoor; anonymous/weak login
23/tcp	Telnet	High	Clear-text credentials and session data
139,445/tcp	Samba (SMB)	High	File sharing, historically vulnerable to remote exploits
3306/tcp	MySQL	High	Database directly reachable, often with weak/default credentials
512-514/tcp	rlogin/rsh (r-services)	High	Trust-based remote login with little or no authentication
25/tcp	SMTP	Medium	Mail relay/version disclosure, possible open relay
22/tcp	SSH	Medium	Admin access point; risk depends on credential strength
53/tcp	DNS	Medium	Can leak zone information if misconfigured
80/tcp, 8180/tcp	HTTP / Tomcat	Medium	Web applications with known vulnerable demo apps
111,2049/tcp	RPC / NFS	Low-Medium	File sharing service, risk depends on exported shares
6000/tcp	X11	Low	Rarely reachable externally in practice but weak by design

Analysis of Results (20%)

Entry-point analysis: FTP, Telnet, the r-services and SMB stand out because they offer either a known backdoor, clear-text credentials, or trust-based login with effectively no real authentication - each is a near-direct path to a shell. MySQL exposes the data layer directly. SSH and the web services are medium risk because they still require valid credentials or a specific application flaw.

How this guides a penetration tester: highest-value, easiest wins (High risk row) are tried first, since weak or backdoored authentication gives the fastest foothold; version numbers from -sV are checked against exploit databases for each service; once initial access is gained through one of the High-risk services, the Medium-risk services (web apps, SSH) become the next pivot or privilege-escalation targets; Low-risk services are kept for completeness and later lateral-movement opportunities.

Documentation (15%)

Findings are documented as a table of port, service, version, risk level and recommended next test, which becomes the basis of the penetration-test plan and, after exploitation is complete, the remediation report for the lab owner.

3. Windows workstation 192.168.56.102 - enumeration before joining the production network, least-privilege review and hardening. (20 Marks)

Conceptual Understanding (20%)

Before a new workstation is connected to a production network, its exposed services must be reviewed against the **principle of least privilege**: only the services actually required should be running and reachable, and every extra open service is unnecessary risk.

Model Design (25%)

Plan: enumerate all ports and services, separate file-sharing and remote-management services from the rest, check each against business need, and design hardening steps for anything that should not be exposed.

Tool Usage (20%)

Commands used:

```
nmap -p- -sV -O 192.168.56.102              # full port, service and OS scan
nmap --script smb-enum-shares,smb-os-discovery -p445 192.168.56.102   # SMB/file-share detail
nmap --script rdp-enum-encryption -p3389 192.168.56.102               # RDP detail
```

Typical findings for a default Windows workstation image (confirm against your own scan):

Port	Service	Category	Comment
135,139,445/tcp	RPC / NetBIOS / SMB	File sharing	Needed only if the host shares files; otherwise should be disabled or firewalled
3389/tcp	RDP (Remote Desktop)	Remote management	High-value target for brute force; should be restricted to management network, with NLA and MFA
5357/tcp	WSDAPI / Device discovery	Default Windows service	Rarely needed; increases surface with no business benefit
49152-49157/tcp	Dynamic RPC ports	Supporting services	Normal Windows behaviour but widens the scanned surface

Analysis of Results (20%)

Least-privilege review: SMB and RDP are the services most likely to be left open beyond what the workstation's role requires; if the machine does not need to share files or be remotely administered from the general network, these should be disabled or limited to a management subnet. Default discovery services are enabled by Windows defaults rather than by a deliberate decision, which is itself a least-privilege violation.

Attacker use of these services:

- **Reconnaissance:** SMB and RPC can reveal the hostname, domain, OS build and sometimes user/share names (enumeration).
- **Lateral movement:** SMB is the classic path used by worms and attackers to move between Windows machines once one host is compromised.
- **Unauthorized access:** RDP is commonly targeted by credential-stuffing and brute-force tools; a successful login gives full interactive access.

Documentation (15%)

Hardening recommendations: disable SMB/file sharing unless required, and if required restrict it by firewall rule to specific hosts; disable RDP for general users and, where needed, require VPN access, Network Level Authentication and MFA; turn off unused discovery/default services; keep the OS patched (particularly SMB-related updates); enable the host firewall with a default-deny inbound policy; and re-scan after hardening to confirm the exposed surface has been reduced before the workstation joins production.

4. OWASP Juice Shop server 192.168.56.103 - enumeration before a web application penetration test. (20 Marks)

Conceptual Understanding (20%)

Before testing a web application, the surrounding network exposure must be understood: which ports and supporting services exist around the web application itself, since vulnerabilities are not always only in the application code.

Model Design (25%)

Plan: host discovery, full port scan, service/version detection, OS fingerprinting, and web-specific identification (web server, technology, any administrative interfaces).

Tool Usage (20%)

Commands used:

```
nmap -sn 192.168.56.103                          # host discovery
nmap -p- -sV -O 192.168.56.103                   # full scan + OS fingerprint
nmap --script http-title,http-headers,http-enum -p80,443,3000 192.168.56.103   # web service identificat
```

Typical findings (OWASP Juice Shop is normally served on port 3000 by default; confirm the exact port from your own scan):

Port	Service	Role for the web application
3000/tcp (or 80/443)	Node.js / Express serving Juice Shop	The web application itself - the primary test target
22/tcp	SSH	Administrative access to the host running the application
Other open ports (if any)	Supporting services (e.g. a database port)	Back-end storage for the application - a secondary target

Analysis of Results (20%)

Support for the application: the web port carries the actual front end and API the testers will attack; SSH is the operational access point for the server rather than part of the application; any database port found supports data storage behind the app and, if directly reachable, is an additional risk beyond the web layer.

Risk evaluation: an exposed administrative interface (SSH, or any application admin panel) widens the attack surface beyond the intended test scope; a directly reachable database port is high risk because it may bypass the application's own access controls entirely; the web service itself carries the expected application-layer risks (injection, broken access control, and so on, per OWASP Top 10) that the later penetration test specifically targets.

Use of enumeration results for the web test: the identified technology stack (Node.js/Express) and version information focus the choice of test cases and known framework vulnerabilities to check; any extra open ports found alongside the web service are reported as out-of-scope findings or added to scope with client approval, since they are part of the real attack surface.

Documentation (15%)

Recommendations: expose only the web application port to the testers/users who need it; firewall the database and administrative ports from anything but the management network; keep the Node.js runtime and dependencies patched; disable any default or debug administrative endpoints before go-live; and document every discovered service with its role so the web penetration test report distinguishes application-layer findings from network-layer ones.

5. Network gateway 192.168.56.1 - enumeration of management services and hardening recommendations. (20 Marks)

Conceptual Understanding (20%)

A gateway device sits between the internal lab network and the outside, so any management service left open on it is especially sensitive: compromising the gateway can expose or redirect traffic for the whole network behind it.

Model Design (25%)

Plan: port scan, service detection, OS fingerprinting and script-based enumeration focused on management protocols (SSH, Telnet, SNMP, HTTP/HTTPS admin pages).

Tool Usage (20%)

Commands used:

```
nmap -sV -O 192.168.56.1                              # service + OS fingerprint
nmap --script snmp-info -sU -p161 192.168.56.1        # SNMP enumeration (UDP)
nmap --script http-title,http-headers -p80,443 192.168.56.1   # web admin interface
nmap -p22,23 192.168.56.1                              # SSH / Telnet check
```

Typical management services found on a lab/home-style gateway (confirm against your own scan):

Service	Risk if exposed	Security implication
Telnet (23)	High	Clear-text credentials; should never be used for management
SNMP (161/udp), especially v1/v2c	High	Default community strings (e.g. “public”) leak device configuration and can allow changes
SSH (22)	Medium	Secure in principle, but risky with weak passwords or default credentials
HTTP admin page (80)	Medium-High	Unencrypted login to the device’s management console
HTTPS admin page (443)	Medium	Safer than HTTP, but still risky with default credentials or outdated firmware

Analysis of Results (20%)

Any management protocol reachable from the internal network (and especially from outside it) is a direct path to the device that controls routing, DNS and often Wi-Fi for every connected host. Telnet and SNMP with default community strings are the most dangerous because they offer little or no real authentication and transmit data in clear text.

How attackers could exploit misconfigurations: sniff Telnet credentials on the local network; use default/public SNMP strings to read or rewrite the device configuration; brute-force or use default credentials on SSH or the HTTP/HTTPS admin page; once logged in, change DNS settings, open additional ports, pivot into the internal network, or intercept traffic for every device behind the gateway.

Documentation (15%)

Recommendations: disable Telnet entirely and use SSH with key-based authentication instead; disable SNMP v1/v2c or move to SNMPv3 with authentication and encryption, and never leave default community strings in place; serve the admin interface only over HTTPS with a valid certificate, never HTTP; change all default credentials and enforce strong, unique passwords (and MFA where supported); restrict management access to a dedicated management VLAN or specific trusted IPs; keep the gateway firmware patched; and disable any management service that is not actually needed, re-scanning afterward to confirm the exposed management surface has been minimized.

RUBRICS FOR CALCULATION

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)	Mark
Conceptual Understanding	20%	Demonstrates strong understanding of underlying concepts in the simulation	Shows good understanding with minor gaps	Partial understanding; some misconceptions	Lacks understanding of key concepts	
Model Design	25%	Develops accurate, well-structured simulation/model independently	Develops correct model with minor errors	Model is incomplete or requires guidance	Unable to develop a proper model	
Tool Usage	20%	Uses simulation tools effectively with correct setup and execution	Uses tools with minor errors or guidance	Limited ability to use tools properly	Unable to use simulation tools	
Analysis of Results	20%	Provides clear, logical analysis and meaningful interpretation of results	Analysis is reasonable with minor gaps	Superficial analysis; limited interpretation	Unable to analyze or interpret results	
Documentation	15%	Presents results clearly with proper documentation and structured reporting	Documentation is adequate with minor issues	Poorly organized or incomplete documentation	No proper documentation or presentation	